NOTE DE SYNTHÈSE · VERSION 1.0

# Ce qui est testé, ce qui ne l'est pas

Serveur MCP intelligent de renseignement sur les menaces — TEK-UP SSIR

Cette note ne remplace pas le rapport : elle isole ce qui a été réellement exécuté, ce qui reste déclaratif et ce qui n'a pas été testé. Elle est écrite pour le jury, puis pour l'équipe qui reprendra le projet : chaque affirmation renvoie à un fichier de preuve ou à une commande rejouable.

**31 / 31**
**scénarios réussis**
0 échec

**16 / 16**
**abus maîtrisés**
100 % de détection, aucune fuite

**12,42 ms**
**latence p95**
60 requêtes · cible ≤ 50 ms

**8 → 0**
**faiblesses comparées**
maquette naïve → serveur durci

## 1. Résultat d'ensemble

La campagne finale du 27 octobre 2026 a exécuté 31 scénarios sur le serveur durci. Les chiffres ci-dessous sont ceux du journal de campagne, pas des estimations.

| Indicateur | Valeur | Lecture | Source |
|---|---|---|---|
| **Scénarios** | 31 / 31 | 14 nominaux · 1 durcissement · 16 abus | preuves/logs/tests_latest.json |
| **Abus** | 16 / 16 | 100 % refusés ou neutralisés | mêmes preuves, catégorie abus |
| **Latence** | p95 12,42 ms | n = 60, audit actif, cible ≤ 50 ms | métriques de campagne |
| **Révocation** | 10,0 ms | sur la requête suivante | commande mesurée à 121,31 ms |
| **Audit** | 115 / 115 | 116 entrées, chaîne valide | une erreur de protocole incluse |
| **Injection** | 3 / 3 | 0 faux positif sur 11 bulletins bénins | corpus unitaire |
| **Comparaison** | 8 → 0 | mêmes 8 contrôles, maquette puis serveur | baseline_naive.py |
| **Durcissement** | uid 65534 | base 0440, clé 0400, 0 port | setpriv, aucune écoute |
| **Données** | 12 · 30 · 6 | bulletins, indicateurs, actifs synthétiques | init-db, aucune donnée réelle |
| **Outils** | 6 | lecture seule, découverte MCP | tools/list, readOnlyHint |

*Lecture : le projet ne se contente pas de « fonctionner » ; il échoue proprement. Les 16 abus sont refusés avec un message générique, journalisés avec un motif distinct, et le journal reste vérifiable.*

## 2. Statuts de livraison

**Statuts utilisés dans ce document : ■ testé ■ configuré ■ proposé ■ déclaratif**

| Statut | Périmètre | Preuve ou réserve |
|---|---|---|
| **Testé** | serveur, ABAC, masquage, audit, révocation, durcissement | 31/31, 115/115, 8 → 0 |
| **Configuré** | base synthétique, 6 outils, journal local, sauvegardes | 12/30/6, init-db, backups |
| **Proposé** | systemd, isolation réseau, HTTP/OAuth 2.1/mTLS, ancrage externe | écrits, non exécutés en production |
| **Déclaratif** | agent EDR, chiffrement de disque, posture | signal déclaré, non attesté |

*Un statut n'est ni une intention ni une promesse : « testé » signifie rejoué et mesuré ; « proposé » signifie écrit mais pas exécuté dans ce laboratoire.*

# 3. Ce qui est testé

Les 31 scénarios se répartissent en huit familles. Chaque famille cite les exigences qu'elle valide ; le détail ligne à ligne figure dans le rapport et dans le JSON de campagne.

| Famille | N | Ce qui est prouvé | Exigences |
|---|---|---|---|
| **Protocole et outils** | 6 | initialize, 6 outils en lecture seule, ressources filtrées, entrées invalides | EF-01, EF-10, EF-12 |
| **Habilitation et cloisonnement** | 10 | niveaux 0 à 3, compartiments, IDOR, rôle et finalité, recherche | EF-03, EF-06, EF-11 |
| **Masquage et injection** | 2 | source Secret masquée, canari, consigne hostile neutralisée | EF-04, EF-05, ENF-12 |
| **Renseignement et score** | 3 | décroissance d'un indicateur, corrélation de famille, score explicable | EF-06, EF-07 |
| **Jetons et posture** | 5 | jeton absent, expiré, altéré, révoqué ; poste non conforme | EF-02, EF-09, ENF-04 |
| **Audit et persistance** | 2 | redémarrage sans perte, falsification détectée | EF-08, ENF-08 |
| **Réseau, débit, dépendances** | 2 | aucun client réseau, limiteur de débit, stdlib uniquement | EF-13, ENF-05, ENF-10 |
| **Durcissement** | 1 | uid 65534, base 0440, clé 0400, écriture refusée | ENF-06, ENF-07 |

## Couverture des exigences

24 des 25 exigences (13 fonctionnelles, 12 non fonctionnelles) sont citées par au moins un scénario. La 25e, ENF-03 — 100 % des appels attendus journalisés — est vérifiée par la mesure d'audit et non par un scénario : 115 appels sur 115, 116 entrées dont une erreur de protocole, chaîne valide. Aucune exigence n'est laissée sans preuve.

Trois scénarios méritent d'être cités au jury : A06 et A07, qui tentent deux fuites distinctes — habilitation insuffisante puis défaut de cloisonnement — et A14, qui falsifie une copie du journal et vérifie que la rupture de séquence est détectée.

## Ce que le jury peut vérifier en séance

- **Fuite —** le jeton Confidentiel lit un bulletin Secret : refus générique, deux motifs distincts dans le journal.
- **Injection —** un bulletin partenaire contient une consigne hostile : elle est signalée et neutralisée avant livraison.
- **Audit —** la commande verify-audit renvoie ok=true, entries=116 ; une copie falsifiée casse la chaîne.
- **Durcissement —** le processus tourne sous uid 65534, la base est en 0440, la clé en 0400, aucun port n'écoute.

## Repères horodatés de la campagne

| Heure | Étape | Preuve |
|---|---|---|
| **13:08** | Premier essai : échec réel de l'audit sur la deuxième écriture | iteration_01_echec_audit.txt |
| **13:14** | Correction du décodage dans audit._last, puis rejeu | même trace |
| **13:16** | Campagne complète : 31/31, 16/16 abus | tests_latest.json |
| **13:21** | Démonstration isolée : fuite bloquée | demo_transcript.txt |
| **14:21** | Captures et figures régénérées | preuves/captures, figures |

# 4. Ce qui n'est pas testé

Une limite nommée n'est pas un échec caché : c'est une condition de production identifiée. Le tableau donne la conséquence réelle et la façon de lever chaque limite.

| Limite | Statut | Conséquence | Condition de levée |
|---|---|---|---|
| **Isolation réseau par espace de noms** | proposé | le test n'a pas été exécuté ; l'absence de client réseau est vérifiée statiquement | lancer le serveur sans interface et vérifier zéro socket |
| **Agent EDR et chiffrement de disque** | déclaratif | la posture est un signal déclaré, pas une preuve cryptographique | agent signé, attestation vérifiée, test de challenge |
| **Ancrage externe du journal** | absent | une réécriture complète par un attaquant root n'est pas exclue | horodatage signé externe ou support WORM |
| **HTTP, OAuth 2.1, mTLS** | proposé | le transport est stdio local, sans port ni fédération d'identité | passerelle HTTP, mTLS, OAuth, tests de rejeu |
| **Charge et concurrence** | non testé | 60 requêtes locales sur un seul poste, pas de multi-clients | banc de charge, SQLite WAL ou serveur dédié |
| **Données réelles** | hors périmètre | jeu synthétique RFC 5737 et .example, aucune donnée client | anonymisation et accord de traitement |
| **Détection d'injection** | heuristique | 3/3 sur le corpus, 0 faux positif sur 11, mais pas de garantie sémantique | corpus adversarial élargi, classification dédiée |
| **Unité systemd** | proposé | le service tourne par setpriv en laboratoire ; l'unité n'est pas installée | installer, activer, redémarrer, vérifier l'uid |

## Priorités avant toute production

- **Intégrité —** ancrer le journal à l'extérieur du poste, par horodatage signé ou support WORM.
- **Transport —** ajouter une passerelle HTTP avec mTLS et OAuth 2.1, puis rejouer les 16 abus.
- **Confiance —** remplacer la posture déclarative par un agent signé et un test de charge multi-clients.

*Ces limites ne s'excusent pas : elles se citent avec leur condition de levée. Le serveur est sûr dans son périmètre de laboratoire, pas encore en production.*

## Deux questions à anticiper

**Le journal est-il inviolable ?**

Non. La chaîne détecte une altération locale, pas une réécriture complète par un attaquant root. C'est pourquoi l'ancrage externe est la première priorité avant production.

**Pourquoi ne pas avoir testé HTTP ?**

Le transport stdio local réduit la surface et suffit à la démonstration. HTTP, OAuth 2.1 et mTLS sont proposés et documentés, pas revendiqués comme testés.

# 5. Conditions de rejeu

Les commandes ci-dessous partent du dossier du projet, sur la même machine que la campagne. Elles n'utilisent que la bibliothèque standard de Python 3.14.4.

```
cd /root/tekup-mcp-ti
python3 tests/run_tests.py
# attendu : 31/31, 16/16 abus, p95 ≤ 50 ms
python3 scripts/demo_defense.py
# attendu : fuite bloquée, Secret autorisé, injection neutralisée
python3 src/ti_cli.py verify-audit --path preuves/lab/audit.jsonl
# attendu : ok=true, entries=116
```

### Pièces jointes et traces

| Fichier | Contenu | Dossier |
|---|---|---|
| **tests_latest.json** | 31 scénarios, métriques, limites | preuves/logs/ |
| **metrics_latest.json** | latence, révocation, audit, injection | preuves/logs/ |
| **demo_transcript.txt** | démonstration de fuite bloquée | preuves/logs/ |
| **01 à 07_*.png** | 7 captures d'écran réelles du terminal | preuves/captures_ecran/ |
| **audit.jsonl** | journal chaîné, 116 entrées | preuves/lab/ |

# 6. Ce que l'équipe retient

- **Journal d'abord —** un contrôle non journalisé n'est pas un contrôle : l'échec fermé a dicté la conception du journal avant celle des outils.
- **Décider et étiqueter ensemble —** masquer à la sortie ne suffit pas ; la décision d'accès et l'étiquette doivent être calculées au même endroit.
- **Garder la maquette —** la version naïve a été conservée pour mesurer les 8 faiblesses, pas seulement pour montrer le résultat final.

# 7. Dossier remis

| Livrable | Contenu | Dossier |
|---|---|---|
| **Rapport PFE** | 35 pages, DOCX + PDF, sommaire, figures et tableaux numérotés | docs/rapport/ |
| **Deck de soutenance** | 16 diapositives, PPTX + PDF, notes orales et questions jury | docs/deck/ |
| **Conducteur** | 19 pages A4, une page par diapositive, plan de secours | docs/deck/ |
| **Note de synthèse** | ce document, 4 pages, DOCX + PDF | docs/note_synthese/ |
| **Preuves** | 7 captures réelles, 31 tests, journaux JSON, audit chaîné | preuves/ |

# 8. Conclusion

Le projet est défendable sur ce qu'il prouve : 31 scénarios, 16 abus maîtrisés, 8 faiblesses neutralisées, 115 appels journalisés sur 115, et un durcissement vérifié. Il ne prétend pas être prêt pour la production : huit limites sont nommées, dont quatre directement techniques, et chacune a sa condition de levée. La soutenance doit dire les deux, sans masquer l'un par l'autre.

**Phrase à retenir** **« Le secret n'est pas une promesse de politique : c'est une propriété testée, et les limites restantes sont nommées. »**

**Mzabi Sirine · Khaled Ellif**

Encadrant académique : Tarek Hdji

TEK-UP — Spécialité SSIR · 27 octobre 2026 · Version 1.0